

Table des matières

TBP — Gouvernance d’actions attestée	1
Note technique v1.4.9 · 18 septembre 2026 · Philippe Collet	1
0 · Résumé	1
1 · Doctrine	2
2 · Modèle de menace	3
3 · Handshake inter-entités	3
4 · Signature d’actions (niveau machine)	4
5 · Architecture réseau d’entreprise	7
6 · Registre : architecture à deux niveaux	8
7 · Cluster : cellules, époques, miroirs, canari	9
8 · Matrice menaces ↔ mécanismes	10
9 · Coût réel et conditions de retrait	11
10 · Ce que le système ne prétend pas	12
11 · Questions ouvertes	13
13 · Mapping et séquence d’implémentation	15
14 · Glossaire de normalisation	15
15 · Statut épistémique	16
16 · Changelog	16

TBP — Gouvernance d’actions attestée

Note technique v1.4.9 · 18 septembre 2026 · Philippe Collet

This document is in French; translation to English is planned but not done yet — see the [repository README](#) for an English summary of what’s covered in each section, and for the configuration guidance derived from it.

« Le contrôle d’accès existant décide si tu entres ; TBP décide ce que tu peux faire une fois dedans — et le prouve. On gouverne les capacités, pas les modèles. »

TBP ne remplace pas les protections métier : la centrale a ses verrous, le LLM a ses guardrails. TBP donne un switch activable et auditable. Si le traducteur ne sait pas, il n’autorise pas : il demande. Si le métier dit non, l’action meurt. Si le métier dit oui, l’action passe. Si c’est gris, l’action est soumise.

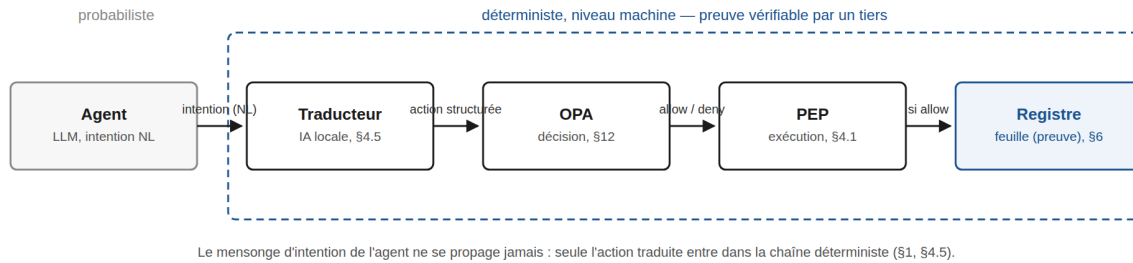
Intègre : audits adversariaux indépendants (Gemini, DeepSeek, Claude — v1.1-v1.3) · audit pratique quatre évaluateurs + deux méta-audits (référence de déploiement v1.2) · manifeste réseau (intégré et normalisé).

Implémentation : ce document fait partie du dépôt [TBP-NETWORK](#) — voir le [README](#) pour la structure du dépôt, la séquence de déploiement (§13) et les configurations de départ (config/, policies/).

0 · Résumé

TBP gouverne les **capacités des agents**, pas leurs modèles. Un LLM est probabiliste : la sécurité ne peut jamais dépendre de ce qu’il produit — elle dépend de ce que son action est autorisée à faire, vérifié par un système déterministe avant exécution, avec preuve vérifiable par un tiers.

Nouveautés de la v1.4 : passeports à capacité bornée (quota signé, compteur au PEP, enveloppe d’egress par époque, télémétrie de métadonnées) · clés éphémères · temps



Objet	Mécanisme	Analogue
Actions	tokens signés (action + temps + portée + quota)	—
Entités	attestation liée à politique (handshake)	mTLS + attestation TEE

2 · Modèle de menace

Attaquants : agents malveillants ou détournés, machines non gouvernées, insiders, et un attaquant capable de faire tomber, **isoler**, remplacer ou **submerger** des composants — y compris en contrôlant le **timing** (retards, partitions, fenêtres).

Non couverts par la prévention (couverts par détection) : hotspot/4G, modèles locaux, accès physique à une machine non gouvernée.

Hypothèse de confiance : clés de gouvernance (HSM, m-of-n) ; au moins un moniteur indépendant ; canal hors-bande authentifié pour la genèse ; contrôleurs joignables par canal séparé (§7.2).

3 · Handshake inter-entités

Le handshake prouve trois choses : **(1) sous quelles règles l'entité opère** (`policy_id = hash(P)`, subsomption mécanique) ; **(2) que son historique est continu** (preuve de consistance $O(\log n)$; toute modification est un événement de transition signé ; discontinuité = corruption = refus) ; **(3) qu'elle est opérationnelle à l'instant** (nonce vérifieur → cycle réel OPA → feuille → signature HSM ; cibles n'acceptant que des tokens émis in-flight).

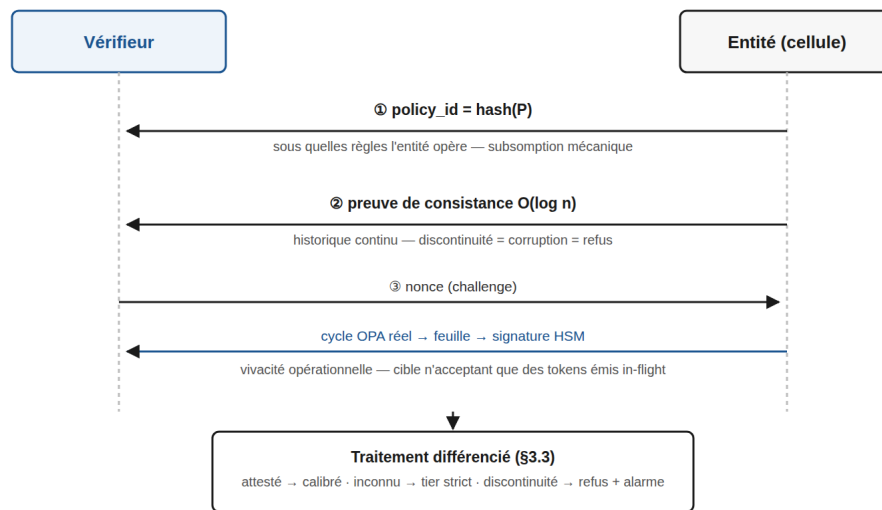


Figure 2: Figure 2 — Handshake

3.2 · Bootstrap : genèse, arrivants tardifs, limite de légitimité

L'époque 0 est signée par le quorum de contrôleurs et ancrée externe dès la genèse. L'arrivant tardif vérifie la chaîne de clés (hors-bande), une preuve de consistance $O(\log n)$, et

la continuité des transitions. **Limite explicite** : le bootstrap prouve la non-altération, pas la légitimité — l'attaque de la genèse parallèle (TOFU) passe tous les contrôles de consistance ; la légitimité vient de l'annuaire référencé (type eIDAS), hors protocole.

3.3 · Traitement différencié

État présenté	Traitement
Attesté, politique sous-sondant	passage calibré selon la classification
Non attesté / inconnu	tier strict : effets de bord bloqués ou arbitrés, egress borné
Discontinuité inexpliquée	refus + alarme moniteur

Positionnement : TBP n'est ni NAC, ni Zero Trust (NIST SP 800-207), ni l'authentification d'entités (PKI, APKI, SPIFFE). Il ajoute : la sémantique de l'action, le tier d'arbitrage humain, la preuve vérifiable par un tiers.

4 · Signature d'actions (niveau machine)

4.1 · Mécanisme et classification

Token signé (Ed25519, TTL 30-60 s, portée = action + ressource, jti unique) délivré après décision OPA ; **PEP local** valide signature + fraîcheur + portée + non-consommation. Debian : `nftables redirect` ; Windows : service PEP. Chaque décision laisse une feuille dans la chaîne de cellule.

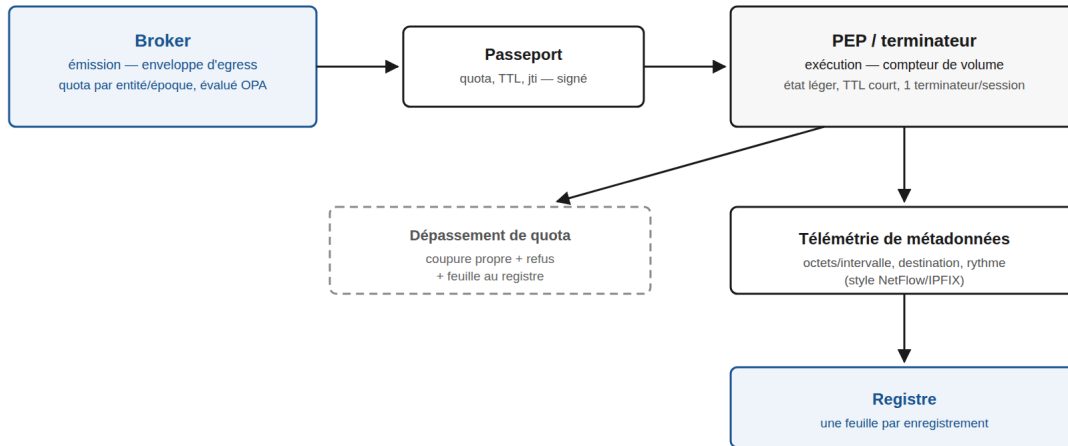
- **Inoffensive** (lecture seule) → exécution directe, sub-ms.
- **À arbitrer** (effet de bord) → validation humaine.
- **Hors périmètre** → refus immédiat + proposition de reformulation.

4.1-bis · Passeports à capacité bornée

Toute ouverture de chemin lourd (session, tunnel, règle SDN) est délivrée sous forme de passeport : un token étendant le token d'action par un vecteur de quota (ressource, opération, volume_max, fenêtre, TTL, jti) — cryptographiquement lié et signé, jamais dans une règle modifiable hors bande.

- **Compteur à l'exécution** (PEP / terminateur) : décrémente le volume ; état data-plane léger, TTL court — même motif que le cache jti ; une session a un seul terminateur. Dépassement = coupure propre + refus + feuille.
- **Enveloppe d'egress à l'émission** (broker) : quota agrégé par entité et par époque, évalué par OPA à la délivrance — ferme l'agrégation de passeports légitimes.
- **Télémetrie de métadonnées** : octets par intervalle, destination, rythme (style NetFlow/IPFIX) ; feuilles du registre. **L'inspection du contenu des flux du passeport est proscrite** — elle détruirait le gain de vitesse du plan de données : l'anti-dribble repose exclusivement sur le post-traitement des métadonnées de flux (goutte-à-goutte, exfiltrations sous-seuil).
- **Doctrine** : prévenir ce qui coûte peu, détecter ce qui coûte cher — toute porte ouverte naît avec son compteur et son instrument (§5.3).

Séparation des températures : quota = compté à l'exécution (PEP) ; enveloppe = comptée à l'émission (broker).



Interdit (§4.1-bis) : inspecter le contenu des flux. L'anti-dribble repose exclusivement sur le post-traitement des métadonnées.

Figure 3: Figure 5 — Passeport à capacité bornée

4.2 · L'arbitrage est une signature, pas une lecture

Le plan présenté à l'opérateur est généré par l'agent (probabiliste) et pourrait mentir (plan abstrait bénin masquant un chemin destructeur). Parade : **le plan approuvé est un contrat** — l'exécution est vérifiée contre le hash du plan validé ; déviation = refus.

4.3 · Anti-rejeu

Signature + fraîcheur + portée ne répondent pas à « déjà consommé ? ». Chaque PEP tient un **cache de tokens consommés à TTL borné** ; chaque feuille d'exécution porte le jti. Rejeu borné à N répliques atteignables par fenêtre TTL (paramètre de spec) ; classes F/W closes par idempotence côté service.

4.4 · Écart ordre → effet (aliasing sémantique)

L'intégrité de l'effet appartient au métier. Le PEP valide l'enveloppe, pas les effets cachés (triggers, cascades). Mitigations bornées aux classes F/I/W, sur deux niveaux — **par action** puis **par séquence** — parce qu'une politique qui ne juge qu'une action à la fois ne peut, par construction, jamais voir un effet qui n'existe qu'au niveau de la séquence.

Par action : (1) **dry-run avec diff d'état** soumis à OPA avant commit ; (2) object-capabilities (token scellé sur hash objet/champ/valeur) ; (3) **PEP in-process** — pour PostgreSQL, extension avec blocage à post_parse_analyze (pré-planificateur : ExecutorStart seul est post-planning, une fonction à effet de bord peut y être déjà évaluée) ; (4) contract-driven — **une API sans invariants déclarés est classée W**.

Par séquence, hérité du moteur de politique OPA du dépôt protocole (Responsible-Alliance-Protocol — voir README, Relation to the main TBP repository) : (5) profil comportemental à état, par agent — fenêtres glissantes 24 h / 7 j (montant et nombre cumulés, fréquence de rafale, dérive comportementale par écart à une base EMA, similarité et anomalies temporelles) ; score composite versionné comme **entrée OPA de premier rang**, jamais un heuristique hors politique (ex. cumul 24 h au-delà du seuil sans approbation humaine = refus, quel que

soit le statut individuel de chaque action composant le cumul). Ferme la classe où l'attaque « saucisson » (N actions sous le seuil, effet agrégé au-dessus) échappe par construction à (1)-(4), qui n'évaluent jamais que l'action en cours.

Résidu, anticipé pour fermeture ex-post plutôt qu'ex-ante : une action isolée, de grande ampleur, dont l'effet dévie de l'intention sans être intercepté par (1)-(5), reste possible — c'est le résidu métier du §10 point 5. Il n'est pas laissé sans réponse documentée : la voie de fermeture identifiée est un **post-mortem obligatoire avec reconstruction de la dérive intention → effet**, recalibrant en retour les seuils F/I/W — mais cette voie appartient au module optionnel TBP-GOVERNANCE (Responsible-Alliance-Protocol), pas au périmètre core de TBP-NETWORK ; voir §11.9 pour le statut exact et pourquoi ce module reste délibérément hors du déploiement par défaut.

4.5 · Le traducteur : anti-fraude structurelle et qualité mesurée

Doctrine : l'action exécutée est l'action traduite par le garde sémantique local — le mensonge de l'agent sur son intention ne se propage jamais à l'effet. Le résidu est une **erreur de qualité**, traitée par deux couches indépendantes : le traducteur réduit la probabilité (décomposition, multilingue, 7-8B fine-tuné, grammaire JSON contrainte, vLLM), les règles réduisent l'impact (refus par défaut des actions non couvertes ; erreur vers action couverte et inoffensive = dommage de qualité borné).

- **Gouvernance de la qualité** : précision différenciée par classe ; corpus natif par langue, positif et négatif ; shadow mode ; mesure continue (rejeu du corpus à chaque mise à jour + échantillon humain).
- **Métriques ancrées** : FNR < 0,1 %, FPR < 2 %, calculées par époque, consignées dans la maîtresse. **Format de feuille : agrégats + hash du corpus — contenu jamais en clair** (relie la vie privée §11 au schéma de feuille).
- **Dégradé contrôlé** : dépassement de seuil = tier-shift ou révocation de bundle ; panne du traducteur = rejet du langage naturel, structuré seulement, aucun fallback cloud.

Le traducteur n'est pas l'élément de sécurité (doctrine ci-dessus) : ce n'est jamais lui qui juge une action sûre ou dangereuse — c'est l'action produite qui est jugée par les règles, sans exception (default-deny, §1). Une erreur de traduction ne contourne donc jamais le jugement : elle change quelle action lui est soumise, pas si cette action, une fois soumise, est correctement jugée. Le résidu n'est donc pas « la sécurité contournée par une mauvaise traduction » — les règles s'appliquent, sans faille, à ce que le traducteur produit réellement, aussi imparfait ce produit soit-il. Un résidu plus étroit existe : une action mal classée (mauvais domaine, tag manquant — §11.8) peut manquer la règle écrite pour sa vraie classe, quand cette règle est conditionnée à ce champ plutôt qu'au contenu direct de l'action ; le default-deny (§1) borne ce risque pour l'action non couverte (inconnu = strict), pas pour l'action couverte mais mal étiquetée.

Mais ce résidu lui-même reste **borné par le passeport, pas par la règle qu'il a manquée** : le token émis après décision OPA a pour portée l'action + la ressource précises (§4.1), scellées sur objet/champ/valeur pour les capacités (§4.4 (2)) — jamais un blanc-seing sur la classe. Le PEP revalide cette portée à l'exécution, indépendamment de la branche OPA qui a émis le token (§4.1) ; toute action qui ne correspond pas exactement au token présenté, ou pour laquelle aucun token valide n'existe, est stoppée net. Une classification erronée ne peut donc jamais élargir ce qu'une action peut faire — elle ne peut, au pire, que faire émettre par erreur un token pour **une** action précise, scellée et auditée (chaque décision laisse une feuille, §4.1), qui aurait dû être refusée ou soumise à arbitrage. C'est un mauvais verdict ponctuel sur une action bornée, jamais une échappatoire du dispositif de bornage lui-même. C'est la qualité de ce verdict — pas le bornage — qui reste la partie la moins mûre du système (métriques ci-dessus, §15) ; et la lourdeur vérifiable du reste de la chaîne (dry-run diff, object-capabilities, pattern-analysis §4.4, Merkle, multisig) ne doit jamais se lire comme si elle réduisait le risque

de mauvais verdict — elle borne et audite ce que ce mauvais verdict peut concrètement faire, ce qui est déjà l'essentiel.

Le traducteur est un paramètre de friction, pas un paramètre de sécurité : il éclaire l'action, il ne la décide jamais. Il ne dit pas « dangereux » ou « sûr » ; il dit « je sais traduire » ou « je ne sais pas ». Sa qualité ne détermine pas la sûreté — elle détermine le taux d'escalade et donc la tenabilité du budget de friction (§9.1). Un traducteur trop prudent épuise l'opérateur ; un traducteur trop confiant laisse passer des actions mal traduites, rattrapées par les règles métier ou par le refus par défaut. La métrique pertinente n'est donc pas seulement FNR/FPR au sens strict, mais taux d'escalade et taux de traduction correcte hors refus. La sûreté des classes F/I/W reste portée par les règles, le quorum (§7.5) et l'arbitrage humain.

- **Durcissement runtime** (vLLM/PyTorch) : processus non-root dédié, CAP_DROP_ALL, seccomp strict — dm-verity protège l'image au repos, pas la surface runtime.

5 • Architecture réseau d'entreprise

5.1 • Le mur et l'aiguillage

Aucun chemin direct client → serveur ; le serveur n'accepte que le broker. Le NAC est un **aiguillage** : authentifié (802.1X, EAP-TLS) → VLAN donnant accès au broker ; inconnu → **VLAN captif** dont la seule route est l'enrôlement ou le broker-forcé. EAP-TLS réutilise **la même PKI que le handshake** — une seule infrastructure d'identité. Anti-détour L2 : VLAN serveurs strict, DHCP snooping + DAI, AP isolation.

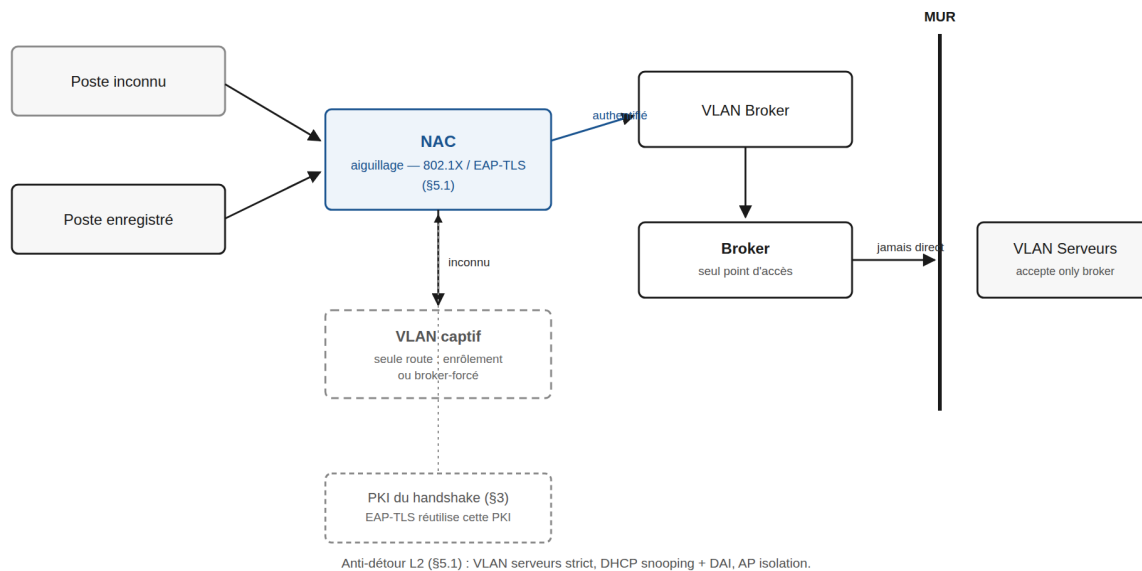


Figure 4: Figure 3 — Topologie réseau

5.2 • Catalogue des chemins hors routeur

Chemin	Fermé par	Résidu / compensation
East-west poste→poste	ACL switch, AP isolation, host firewalls	même-VLAN → segmentation stricte

Chemin	Fermé par	Résidu / compensation
Hardware (USB, Thunderbolt)	USBGuard, GPO, BIOS/IOMMU	extrémité, pas réseau
Hotspot / 4G	— (infundable)	PEP ressources · instrumenté
Modèle local	—	on ne gouverne pas le cerveau
Console / iLO / admin	VLAN mgmt, jump hosts, actes journalisés	admin = entité la plus auditée
Poste non enregistré	NAC → broker-forcé / VLAN captif	—

5.3 · Doctrine des trous

Un trou non instrumenté dans le mur est une porte. Un trou instrumenté est un capteur.

« Instrumenté » exige un **instrument nommé** : télémétrie hôte (intégrité de fichiers, journaux, flux) **alimentée au registre**. Un canal sans instrument laisse des actes non prévus et non vus — seul état interdit.

Classe	Exemples	Exigence
F — financier	paiement, ERP écriture	PEP token + arbitrage + quota
I — infrastructure	prod, CI/CD	PEP token + scoping strict
W — survie	effet de masse	PEP + arbitrage + quorum (\$7.5) + \$4.4
hors F/I/W	lecture, internet	mur + audit (conditions 1 ou 3)

- **La télémétrie est une action de classe W** : la couper — même par un admin sous pression — exige un quorum, est signée, alarmée, consignée.
- **Fail usine** : le défaut « RADIUS injoignable » est souvent fail-open — forcer fail-closed par switch. OCSP/CRL injoignable = VLAN de remédiation avec feedback, jamais soft-fail aveugle.
- **Déploiement** : mode monitor avant closed ; pas de RADIUS-assigned VLAN en v1 ; MAB = canal instrumenté (VLAN IoT dédié, jamais silencieux).

6 · Registre : architecture à deux niveaux

Chaque cellule tient sa propre chaîne (sessions, batchs) — chemin chaud sans coordination. Périodiquement, hash(broker_id, tête, TSA) de chaque cellule est inscrit dans la **chaîne maîtresse** (motif CT, RFC 6962). Moteur : **Tessera** (bibliothèque GA, driver POSIX — un dossier = un log de cellule) ; amorçage : veritrail (tester contre les vecteurs RFC 6962) ; Rekor/cosign = registre d'**artefacts** (\$1), jamais de décisions. Maison complet écarté : la séparation de domaine feuille/nœud est la partie la plus auditée de l'écosystème — et une preuve vérifiable par un tiers perd sa valeur si l'auditeur doit relire le code. Signal d'écosystème : Let's Encrypt migre ses logs RFC 6962 vers l'API Static CT / tiled — la direction Tessera est celle du champ entier.

6.2 · Températures — et le temps explicite

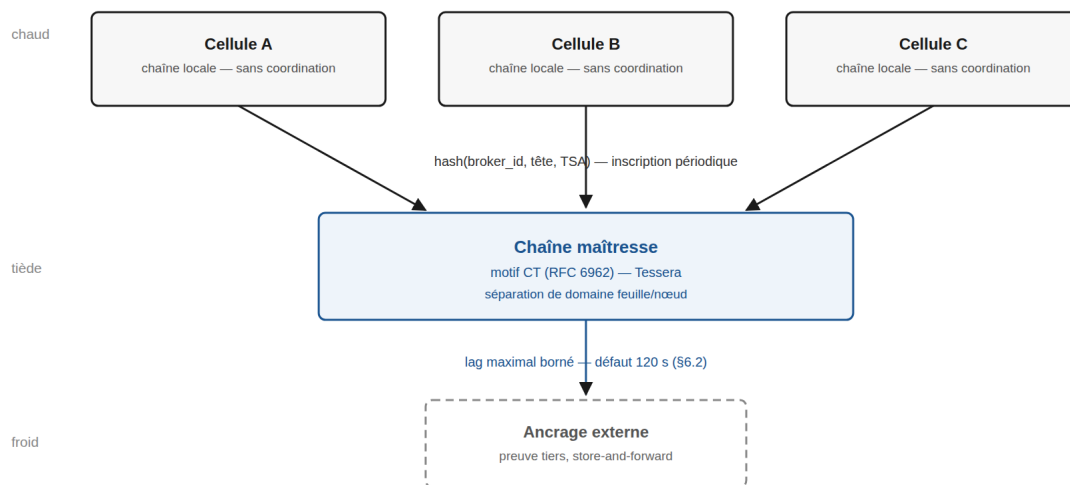


Figure 5: Figure 4 — Registre à deux niveaux

Chemin	Rôle	Pannes tolérées
Chaud : broker + OPA + HSM	décision, token	N+1 stateless, bascule en secondes
Tiède : registres	enregistrement, séquencement	répliqué, idempotent
Froid : ancrage + moniteurs	preuve externe, détection	tiers, store-and-forward

- **Lag maximal borné** : le jeton d'époque porte le hash du dernier ancrage ; le PEP refuse tout token dont l'ancrage accuse un retard > seuil (défaut 120 s). Ferme la submersion : DoS, jamais fenêtre d'impunité. Complément : tier-shift dynamique sous charge.
- **Temps = hypothèse fondatrice explicite** : TTL, époques, TSA et fraîcheur héritent d'une hypothèse d'horloges synchronisées. Exigence : **NTS (RFC 8915)** sur brokers/PEPs, dérive < 5 ms — sinon rejet massif de tokens légitimes = friction systémique.
- **RGPD / rétention** : un append-only infini entre en tension avec les obligations de rétention — feuilles hash-only, salage, politique de rétention explicite.

6.3 • L'état attesté = manifeste

(policy_id, config OPA, hash broker, hash conteneur IA locale, tête de chaîne) — tout changement de composant = transition visible, signée, continue ; le hash est celui du paquet signé (§1). Measured boot : la racine du nœud est mesurée par le TPM/HSM au démarrage.

7 • Cluster : cellules, époques, miroirs, canari

7.1 • Bétail, pas racine de confiance

Le broker n'est pas la racine de confiance ; les clés et la maîtresse le sont. États par cellule ; l'état du système vit dans la maîtresse + l'époque courante. **Le Superviseur est une cellule**

à périmètre élargi + le registre maître — même mécanique, même doctrine, jamais une boîte noire nouvelle.

7.2 • Fencing par époque

Jeton d'époque (N, autorité, TTL ~60 s) signé par les contrôleurs (m-of-n, HSM) ; seule la détentrice sert ; l'ancienne expire seule — deux autorités impossibles. Bascule manuelle : contrôleurs joignables par canal séparé. Automatique pré-autorisée (« max N bascules/heure, ensuite humain ») ; 3 cellules + majorité 2-of-3.

7.3 • Révocation = nouvelle époque

Cellule compromise : époque à roster réduit ; tokens morts ; **quarantaine, pas meurtre** — la cellule gelée sert l'analyse.

7.4 • Miroirs et canari — fenêtre ancrée

Hash du bundle ancré à chaque époque (policy_id = hash des règles = le hash du handshake). **La fenêtre saine est définie et ancrée dans la maîtresse — jamais mesurée par la canari elle-même** (un attaquant réseau peut l'isoler pendant la mesure) ; promotion = preuve de réception du bundle ancré. Une cellule éligible satisfait l'ensemble des exigences externes engagées.

7.5 • Quorum

Actions de classe W : cosignature k-of-n ; une cellule seule ne peut pas autoriser l'irréversible maximal.

7.6 • Compromission entre deux époques — provenance ≠ conformité

Pendant le TTL de l'époque active, un composant qui détient ses clés locales peut émettre des tokens allow que la politique n'aurait pas autorisés. Ce qui reste prouvé : l'imputabilité (il peut mentir sur la décision, pas sur sa responsabilité), la borne temporelle, la protection W, l'impossibilité de réécrire le passé. **Trade-off explicite** : l'OPA local rend cette fraude possible ; la co-évaluation distante la fermerait au prix de la latence — positionnable par classe (par défaut : local tiers 1, co-évaluation F et W).

7.7 • Évolution de politique (agilité sous contrat)

Monotonie vérifiable (§11) ; affaiblissement légitime = transition motivée, visible, mettant à jour le consentement des vérificateurs ; workflow négocié sans arrêt ni fenêtre ; conformité historiquement continue.

8 • Matrice menaces ↔ mécanismes

Menace	Mécanisme	Résidu
Prompt injection multilingue	plancher déterministe + traducteur + auditeur	taux < 100 % (borné)
Fraude par description (agent menteur)	traducteur : l'action exécutée est l'action traduite	fermé structurellement
Erreur de traduction	règles (refus par défaut) + qualité mesurée (§4.5)	dommage de qualité borné

Menace	Mécanisme	Résidu
Plan abstrait mensonge en arbitrage	plan approuvé = contrat hashé	—
Aliasing sémantique	métier primaire + mitigations §4.4 par action et par séquence (F/I/W)	résidu métier : fermeture ex-post anticipée, module optionnel (§11.9)
Rejeu de token	jti + cache PEP + cardinalité F/W	borné à N répliquas ; détectable
Tunnel ouvert (passeport)	passeport à quota + enveloppe + métadonnées (§4.1-bis)	dribble → post-traitement
Contournement local du PEP	re-validation service / peer credentials / eBPF cgroup	—
Machine non gouvernée	NAC aiguillage ; mur ; PEP ressources	hotspot/modèle local : détection
Broker tombé / adverse	stateless N+1 ; fencing ; clés épinglées	DoS alarmé — jamais un acte
Split-brain	époques TTL ; 2-of-3 ; contrôleurs OOB	—
Submersion du registre	lag borné + tier-shift	DoS — jamais d'impunité
Promotion canari sous partition	fenêtre saine ancrée + preuve de réception	—
Cellule compromise intra-époque	TTL + révocation + quorum W	actes imputables, détection post-facto
Vol des clés de gouvernance	m-of-n ; HSM ; quorum	futures signables, passé scellé
Bundle empoisonné	signature + canari ancré	fenêtre canari limitée
Genèse parallèle (TOFU)	— (assumé)	légitimité = annuaire référencé (§3.2)
Admin sous pression (coupure télémétrie)	télémétrie = action W (quorum, alarme)	confiance root assumée ailleurs
Mort par friction	périmètre borné F/I/W + indicateurs (§9)	risque opérationnel n°1

9 · Coût réel et conditions de retrait

Latences cibles : tier 1 < 2-5 ms ; tier 2 : 10-50 ms ; tier W : secondes à minutes. **Le régime de coût change** : d'un coût rare et catastrophique à un coût continu et visible. Les actes évités sont invisibles ; les frictions quotidiennes. **Indicateurs annonciateurs** : arbitrage > 20 % ; validations < 5 s ; trous non instrumentés ; TTL qui s'allongent ; culture des exceptions.

Trois scénarios de retrait : (A) break-glass — débrayage = action gouvernée ; (B) mort par friction (la plus probable) — parade : gouverner strictement F/I/W ; (C) cascade DoS — prix = perte de prouvabilité assumée.

9.1 · Budget de friction — contrainte fondatrice du pilote

L'architecture est utilisable parce qu'elle accepte d'être imparfaite ; cette contrainte est un exigence mesurable, pas une intention :

- **Latence ajoutée tier-1 < 5 ms** (plancher déterministe, mesurée en continu).
- **Taux d'arbitrage humain cible < 10 %** des actions (au-delà : la gouvernance devient le goulot — indicateur §9). Ce taux est directement fonction de la qualité du traducteur (§4.5) : c'est le levier de réglage principal du budget de friction.

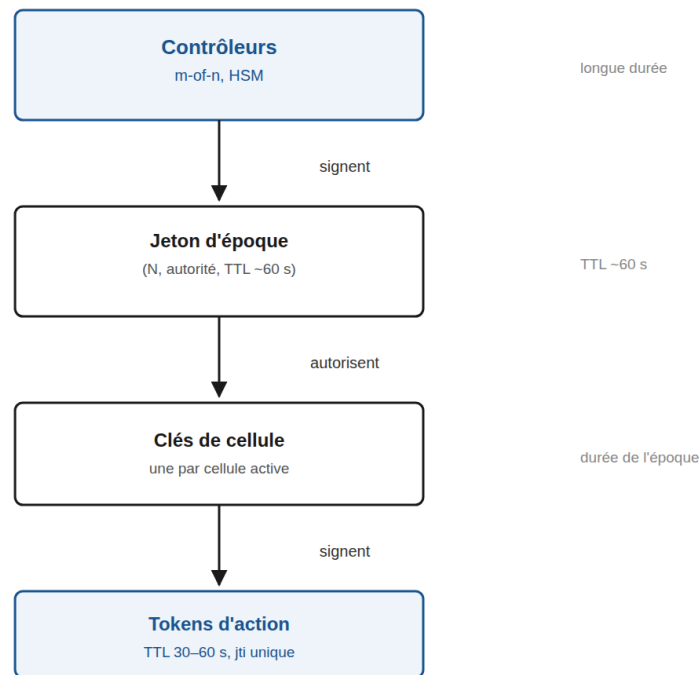


Figure 6: Figure 6 — Hiérarchie de clés et temps

- **Condition d'échec du pilote : régression de l'expérience utilisateur mesurée = 0**
— la protection ne doit jamais se payer en blocage des tâches légitimes.

Seuil de décision : maintenir TBP ssi $P(\text{acte irréversible}) \times \text{coût}(\text{acte}) > \text{coût}(\text{DoS}) + \text{coût}(\text{friction})$.

Time-to-Audit (< 1 semaine vs 3-6 mois) : métrique commerciale — chaîne de preuve à construire avant usage client.

10 · Ce que le système ne prétend pas

1. Pas 100 % secure — **100 % auditable sur périmètre déclaré.**
2. Le traducteur est probabiliste ; la garantie est le plancher.
3. L'attestation engage les règles, non leur exécution parfaite.
4. Le canal hotspot / modèle local est incompressible.
5. L'effet réel d'une action reste la responsabilité du métier.
6. La fraude intra-époque est possible et bornée (§7.6).
7. La légitimité de la genèse n'est pas prouvable par le protocole.
8. L'admin root reste un acteur de confiance — le plus audité.
9. La disponibilité a un prix.
10. La conformité (AI Act art. 14) est le prix d'entrée de l'arbitrage humain ; TBP l'amortit.
11. TBP n'est pas un juge, c'est un livre de lois et un greffe : il éclaire l'action et la rend activable, signée, auditable, sans exercer de discrétion. Le verdict de sûreté appartient aux règles métier (déjà écrites) et à l'arbitrage humain (le gris).
12. Le traducteur n'est jamais l'élément de sécurité : c'est l'action produite, jamais l'intention déclarée, qui est jugée par les règles, sans exception (§4.5) — une erreur de traduction ne

contourne donc pas le jugement. Le résidu réel, plus étroit, est la classification (domaine, tags — §11.8) : une action couverte mais mal étiquetée peut manquer la règle écrite pour sa vraie classe ; le défaut-deny (§1) borne l'inconnu, pas le mal-classé. Mais une classification erronée ne peut faire émettre, au pire, qu'un token mal jugé pour une action précise et bornée (portée scellée sur action + ressource, §4.1 ; sur objet/champ/valeur, §4.4) — jamais élargir ce que cette action peut faire, ni contourner la revalidation de portée au PEP. La lourdeur vérifiable de la chaîne d'application ne réduit pas le risque qu'une classification produise un mauvais verdict ; elle borne et audite ce que ce mauvais verdict peut concrètement faire.

11 • Questions ouvertes

#	Question	État
1	Gouvernance du registre de profils référencés (décentralisé vs qualifié eIDAS) — clé de voûte du bootstrap §3.2, désormais distincte de la classification locale (§11.8)	ouverte
2	Formats de preuve compacts pour vérificateurs faibles	ouverte
3	Langage de règles : monotone, ordre-indépendant, stratifié ; stratification = détection de cycles ; subsomption décidable et linéaire	calibrage établi
4	Traducteur : métriques par classe, corpus, traducteurs redondants	à développer
5	Nom : « Proof of Transit » déjà pris (draft-ietf-sfc-proof-of-transit, IETF SFC — expiré, jamais publié en RFC) — fixer : attestation de gouvernance opérationnelle	à fixer
6	Échelle : fréquence d'ancrage ; preuves compactes	ouverte
7	Vie privée : continuité vérifiable sans exposition de contenu (reliée au format de feuille §4.5)	format établi (agrégats + hash)

11.8 • Gouvernance de la classification

La classification F/I/W est une décision locale, prise par la gouvernance de chaque entité sur son propre périmètre. Il n'y a pas d'autorité centrale de classification. La compatibilité entre entités est vérifiée mécaniquement par le handshake (§3) : `policy_id = hash(P)`, subsomption mécanique. Si la politique de B ne subsume pas celle de A, B refuse ou restreint l'échange.

Conséquence : la légitimité de la classification est celle de la gouvernance qui la produit. Le protocole ne se prononce pas dessus, il la rend vérifiable. L'atelier ne peut pas écrire dans la compta ; la compta peut lire la déclaration de l'atelier et l'écrire dans ses propres registres. Chacun reste souverain chez lui ; les échanges passent par des canaux dont la sémantique est explicitement bornée.

Ce mécanisme vaut à toute échelle : en entreprise (périmètres organisationnels) comme entre institutions (périmètres souverains). Ce n'est pas le même problème politique, c'est le même protocole. La difficulté restante — méta-invariants, hiérarchie des règles, reconnaissance mutuelle des classifications — relève de la négociation entre gouvernances, pas du protocole. TBP ne résout pas ce problème ; il le rend traitable.

11.9 • Fermeture ex-post du résidu d'aliasing sémantique (module optionnel)

Le résidu identifié au §4.4 (action isolée, de grande ampleur, effet dévié de l'intention, non intercepté par les mitigations (1)-(5)) a une voie de fermeture ex-post anticipée mais **délibérément non intégrée au périmètre core** de ce dépôt : **TBP-GOVERNANCE**, module du dépôt protocole (Responsible-Alliance-Protocol), qui ajoute une voie de dérogation multisig (comité 5 rôles, quorum 3-of-5, JWT à durée limitée injecté dans OPA) et rend le post-mortem obligatoire — reconstruction de la dérive intention → effet, analyse d'impact, détection d'urgence fabriquée — sur chaque usage de cette voie.

Pourquoi hors périmètre par défaut : TBP-GOVERNANCE documente lui-même sa propre doctrine (« A bypass is not an evolution. It is a tragic concession to the complexity of the real world ») — prérequis lourds (HSM, comité 24/7, cadre juridique, six mois de TBP-CORE stable sans incident), coût systémique volontairement élevé (fenêtre de confiance érodée à chaque usage, verrouillage définitif si le budget de 24 h de dérogation cumulée sur 12 mois est dépassé), et une recommandation explicite : la plupart des déploiements doivent rester sur le socle sans dérogation. L'intégrer par défaut à TBP-NETWORK transformerait une échappatoire volontairement pénible en confort — la « boiling frog » que le module lui-même met en garde contre.

État : anticipé et documenté — pas une lacune non vue. Intégration dans ce dépôt : ouverte, conditionnée aux mêmes prérequis que ceux du module (checklist infrastructure/gouvernance/légal/observa pas avant le pilote P1/P2 (§13).

Besoin	Brique
Moteur de politique	OPA / Rego (bundles signés, évaluation embarquée)
Transparence	motif CT (RFC 6962) · Tessera (tiled / Static CT)
Attestation	RATS (RFC 9334) · EAT
Identité d'agents	APKI (draft IETF) · SPIFFE/SPIRE
Artefacts	Sigstore (cosign, Rekor, Fulcio)
Horodatage	TSA RFC 3161 (≥2, dégradé signé-local/rattrapé) · Zeitwerk à suivre
Preuve de transit	draft-ietf-sfc-proof-of-transit (notion IETF SFC, expiré ; mécanisme différent — citer)
Réseau / extrémité	nftables · 802.1X (FreeRADIUS/NPS) · hostapd · USBGuard · GPO · NTS (RFC 8915)
Inférence	vLLM/TGI · modèles open-weights 7-8B (Qwen2.5 / Mistral)

Checklists transversales - Ed25519 partout : vérifier avant tout achat — HSM, signature de bundle OPA (historiquement RSA/ECDSA), TSA. - **Portée de signature de bundle** : auditer

les exclude lists. - La signature de bundle ne gère pas la clé — câbler au HSM/m-of-n. - capabilities.json **figé** : pas de http.send, pas de time.now_ns natif ; circuit-breaker 5 ms = deny (fail-closed). - SoftHSM : jamais gouvernance (dev/test). CloudHSM : AWS-only PKCS#11, lock-in — option marginale.

13 • Mapping et séquence d'implémentation

Intra-domaine : mur, PEP, cellules, époques, canari. **Inter-domaines** (note conceptuelle) : handshake, politiques nommées, collection référencée, confiance par contrat.

Séquence : (1) HSM + cérémonie de genèse ; (2) fencing du cluster — émission et rotation des époques, quorum des contrôleurs (k-of-n) pour la classe W, promotion miroir/canari (§7) — requis avant tout déploiement multi-cellules, y compris le pilote P1 à 2 cellules ci-dessous ; une cellule unique peut différer cette étape, un pilote non ; (3) OPA + validateur + registre ; (4) PEP HTTP/gRPC = premier périmètre réellement gouverné ; (5) NAC en parallèle ; (6) traducteur + escalade F/I/W en dernier.

Pilote P1 : 1 VLAN serveurs, routeur Debian, 2 cellules, PEP base + partage, 802.1X, registre central — sous le budget de friction §9.1 (régression utilisateur = 0). **P2 campagne rouge** : scénario « Michel » étendu (portable inconnu, SFTP direct, USB, hotspot, submersion, plan mensonger, promotion canari sous partition, rejeu, coupure de télémétrie). **Métrique non négociable** : zéro action dangereuse non journalisée — les trous comptés, jamais ignorés.

14 • Glossaire de normalisation

Un terme par concept — les synonymes des documents amont (manifeste réseau, références de déploiement) sont mappés ici.

Terme canonique	Synonymes mappés	Définition
cellule	TBP Cellule, enclave, edge	broker + registre local + politiques propres ; état par cellule
superviseur	TBP Supervisor, core, egress	cellule à périmètre élargi + registre maître ; jamais une boîte noire
maîtresse	master chain, chaîne centrale	agrégation des têtes de cellules, ancrée
collection référencée	règles ABC (standard), profils	règles publiques versionnées, hashées, épinglées
règles propres	règles XYZ, règles maison	règles locales signées, non révélées
passport	sésame, capacité, token de session	token à quota (ressource, opération, volume, fenêtre, TTL, jti)
traitement différencié	couloir surveillé, verdict binaire	attesté / strict / refus selon l'état présenté
époque	epoch, fencing, jeton d'autorité	période d'autorité signée, TTL, révocable
traducteur	garde sémantique, traducteur local	IA locale produisant l'action exécutée
manifeste	état attesté, measured state	vecteur mesuré de la pile gouvernée (§6.3)

Terme canonique	Synonymes mappés	Définition
trou instrumenté	capteur, canal instrumenté	chemin hors mur dont la télémétrie alimente le registre

15 • Statut épistémique

Le consensus multi-IA est un filtre contre l’erreur grossière isolée, pas une preuve.

Quatre modèles convergent souvent parce qu’ils partagent un corpus — la preuve, c’est la vérification directe (faite : Trillian maintenance mode, Tessera GA, veritrail) et, au bout du chemin, le pilote en conditions réelles.

Classe	Contenu	Conduite
Principes stables	séparation 0x00/0x01, default-deny, fencing TTL, monotonie	confiance haute — spécifier
Photographies datées	statut GA de Tessera, comptabilité veritrail, posture OPA, modèles/GPU, coûts	dater ; re-vérifier à l’implémentation
À valider en terrain	latences, taux d’erreur du traducteur, budgets ETI, Time-to-Audit	le pilote est la validation

Document vivant — dater la confiance, toute la confiance.

16 • Changelog

Version	Contenu
v1.1 (audit Gemini)	plan arbitré = contrat · mitigations aliasing · lag maximal + tier-shift · instrument nommé · révocation = époque · bootstrap à preuves de consistance · canal OOB · conditions de retrait · calibrage du langage
v1.2 (audit DeepSeek)	fenêtre canari ancrée · limite de légitimité · provenance ≠ conformité · gouvernance de la qualité du traducteur · régime de coût et indicateurs · table des langages
v1.3 (audit Claude)	anti-rejeu jti · localhost ≠ authentification · rejeu chiffré · indicateurs · veritrail vérifié
v1.4.1 (revue indépendante)	corrections textuelles (§1, §8) · anti-dribble explicite : proscription d’inspection de contenu, §4.1-bis · budget de friction ancré comme contrainte de pilote (§9.1) · refonte des figures 1, 2, 3, 5, 6 : flux unidirectionnels clarifiés, palette harmonisée

Version	Contenu
v1.4.9 (cluster manquant de la séquence §13)	§13 : la séquence d'implémentation listait HSM/genèse → OPA/registre → PEP → NAC → traducteur sans jamais nommer le cluster (§7 : fencing d'époque, quorum k-of-n classe W, promotion miroir/canari) comme étape de construction — repéré en relisant un plan d'implémentation dérivé de la séquence, qui héritait donc la même lacune (aucune tâche T1-T28 ne couvrait §7, alors que le pilote P1 est explicitement à 2 cellules). Ajout d'une étape 2 explicite : « fencing du cluster... requis avant tout déploiement multi-cellules, y compris le pilote P1 à 2 cellules... une cellule unique peut différer cette étape, un pilote non » — les étapes suivantes renumérotées (3 à 6)
v1.4.8 (le mal-classé reste borné par le passeport)	§4.5, §10 point 12 : le résidu de classification erronée identifié en v1.4.7 ne se traduit jamais en action à portée élargie — le token émis après décision OPA est scellé sur l'action + la ressource précises (§4.1), ou sur objet/champ/valeur pour les capacités (§4.4 (2)), jamais un blanc-seing sur la classe ; le PEP revalide cette portée à l'exécution indépendamment de la branche OPA qui a émis le token, et toute action sans token valide correspondant est stoppée net. Une classification erronée ne peut donc faire émettre, au pire, qu'un mauvais verdict pour une action précise, scellée et auditée (chaque décision laisse une feuille, §4.1) — jamais une échappatoire du dispositif de bornage lui-même
v1.4.7 (correction : le traducteur n'est pas l'élément de sécurité)	§4.5, §10 point 12 : reformulation de v1.4.6 — le traducteur n'a jamais été « l'élément de sécurité », donc une erreur de traduction ne contourne jamais le jugement des règles : c'est l'action produite, jamais l'intention déclarée, qui est jugée, sans exception (§1). Le résidu réel est plus étroit que ce que v1.4.6 formulait : une action couverte mais mal classée (mauvais domaine, tag manquant — §11.8) peut manquer la règle écrite pour sa vraie classe quand cette règle est conditionnée à ce champ ; le défaut-deny borne l'inconnu (non classé = strict), pas le mal-classé (classé à tort dans une catégorie moins stricte)

Version	Contenu
v1.4.6 (lourdeur ≠ preuve de qualité de traduction)	§4.5 : nouveau paragraphe explicite — OPA/le PEP ne sont jamais contournés (default-deny, §1, sans exception), le résidu est en amont : OPA décide sur l'action traduite, jamais sur l'action réellement demandée si le traducteur ou la classification (§11.8) se sont trompés ; toute la chaîne d'application (dry-run diff, object-capabilities, pattern-analysis §4.4, Merkle, multisig), aussi lourde et vérifiable soit-elle, prouve alors que le système a fait ce que l'entrée disait — pas que l'entrée décrivait correctement ce qui a été demandé · §10 : point 12 (nouveau) nomme frontalement le risque de fausse confiance — la sécurité perçue de l'appareil ne doit jamais se lire comme une preuve de qualité de traduction
v1.4.5 (fermeture de l'aliasing sémantique)	§4.4 : les mitigations F/I/W deviennent explicitement à deux niveaux — par action (1)-(4), inchangées, et par séquence (5) nouvelle, un profil comportemental à état par agent (fenêtres glissantes, dérive EMA, score composite en entrée OPA de premier rang) hérité du moteur de politique du dépôt protocole, fermant la classe d'attaque « saucisson » que (1)-(4) ne peuvent pas voir par construction · le résidu métier restant (action isolée hors (1)-(5)) n'est plus seulement mentionné comme non fermé : §11.9 (nouveau) documente sa voie de fermeture ex-post anticipée (post-mortem + reconstruction de la dérive intention → effet, module optionnel TBP-GOVERNANCE) et pourquoi elle reste volontairement hors périmètre core par défaut · §8 : ligne aliasing sémantique reformulée en conséquence — objectif : ne pas laisser croire que ce résidu n'est pas anticipé
v1.4.4 (précision terminologique)	Élimination de « juger »/« jugement » comme verbe décrivant TBP, y compris à la forme négative : TBP n'exerce aucune discrétion, il n'y a donc rien à juger ni à ne pas juger. §1 : « on éclaire l'action, on ne la juge pas » → « TBP n'est pas un juge, c'est un livre de lois et un greffe » · §4.5 : « il éclaire l'action, il ne la juge jamais » → « il éclaire l'action, il ne la décide jamais » · §10 point 11 : même reformulation (livre de lois et greffe) · §11.8 : « le protocole ne la juge pas » → « le protocole ne se prononce pas dessus »

Version	Contenu
v1.4.3 (clarifications)	§1 : principe « on éclaire l'action, on ne la juge pas » · §4.5 : le traducteur est un paramètre de friction, pas de sécurité ; métriques recentrées (taux d'escalade, traduction correcte hors refus) · §9.1 : lien explicite avec §4.5 · §11.8 : la gouvernance de la classification devient une conséquence du §3 (souveraineté locale + subsomption mécanique), plus une question ouverte · §10 : ajout du point 11 · §0 : épigraphe du switch activable et auditable
v1.4.2 (corrections)	citation erronée corrigée (§11, §12) : RFC 9578 est « Privacy Pass Issuance Protocols », pas « Proof of Transit » — jamais publié en RFC, seulement draft-ietf-sfc-proof-of-transit (IETF SFC, expiré) · glossaire de normalisation (§14) appliqué aux occurrences manquées : « garde »/« garde sémantique » → « traducteur » (§8, §10) ; « Sésame » → « passeport » (§4.1-bis, §8) · coquille §3.3 (« différencié » → « différencié ») · NIST 800-207 → NIST SP 800-207 (§3.3)
v1.4	référence de déploiement v1.2 intégrée (4 passes pratiques + 2 méta-audits) : passeports à capacité bornée · clés éphémères · temps explicite (NTS) · circuit-breaker OPA · extension PG · EAP-TLS = même PKI · OCSP fail-behavior · durcissement vLLM · RGPD/rétention · gouvernance de la classification · glossaire · statut épistémique · manifeste réseau intégré et normalisé

Un standard qui deviendrait global cesserait d'être un standard ; il deviendrait une philosophie. TBP en est une. Le protocole est sa compression pour les techniciens.